

Segurança em Camadas



Defesa em Profundidade

A cada dia, os ambientes corporativos enfrentam desafios crescentes, especialmente aqueles relacionados à proteção de dados, informações, recursos computacionais e infraestruturas de telecomunicações.

Diante desse cenário, as equipes de segurança da informação devem adaptar-se rapidamente às exigências do mundo dos negócios e estar prontas para enfrentar um ambiente cada vez mais hostil. Profissionais de segurança da informação e cibernética precisam estar atualizados com as últimas tendências tecnológicas para projetar, dimensionar e implementar estratégias e mecanismos eficientes e eficazes de segurança. No entanto, proteger a tecnologia da informação em qualquer ambiente corporativo não é uma tarefa simples, pois envolve processos, tecnologias e pessoas.

Assegurar a segurança da informação em um ambiente corporativo significa proteger os ativos de TI contra a perda de confidencialidade, integridade, disponibilidade e autenticidade. Logo, a segurança da informação não é uma única tecnologia isolada, mas sim um conjunto de ferramentas, estratégias e políticas destinadas a proteger a empresa de vários problemas, como ataques virtuais, vulnerabilidades na área de TI, proteção de dados e informações e prevenção de acessos não autorizados.

Uma das estratégias mais eficientes e eficazes para proteger os ativos de TI em um ambiente corporativo é a Defesa em Profundidade (DiD). Essa abordagem consiste na aplicação de medidas defensivas redundantes em camadas, visando implementar políticas, controles, mecanismos e ferramentas tecnológicas redundantes dispostas em camadas. Esse método de segurança em camadas aumenta a proteção da infraestrutura de TI como um todo e aborda muitos vetores de ataque diferentes. Se um mecanismo de segurança falhar, outro será acionado imediatamente para impedir um ataque.

A Defesa em Profundidade é frequentemente comparada à abordagem de um castelo medieval, que possui várias camadas de defesa. Antes de invadir um castelo, é

preciso enfrentar mecanismos de defesa como o fosso, as muralhas, a ponte levadiça, as torres de vigilância e os soldados arqueiros, entre outros.

O mundo digital transformou a maneira como vivemos, trabalhamos e nos divertimos. No entanto, esse mundo está constantemente exposto a ataques, e é necessário garantir a segurança adequada para impedir que a infraestrutura de TI seja comprometida.

Infelizmente, não há um único método capaz de proteger com sucesso contra todos os tipos de ameaças. É nesse contexto que a defesa em profundidade desempenha um papel crucial.

A defesa em profundidade, originária da Agência de Segurança Nacional (NSA), foi concebida como uma abordagem abrangente para a segurança da informação e a segurança cibernética (HARRIS, 2004). Inspirada em uma estratégia militar homônima, a defesa em profundidade na segurança da informação envolve a implementação de sistemas paralelos de contramedidas físicas, técnicas e administrativas que trabalham em conjunto (STALLINGS; BROWN, 2017).

A principal característica da defesa em profundidade é que um ataque em potencial deve ser interrompido por vários métodos independentes (KIM; SOLOMON, 2014). Isso implica que as soluções de segurança devem abordar vulnerabilidades de segurança ao longo do ciclo de vida do sistema, e não em um único momento (SÊMOLA, 2014).

Devido à crescente sofisticação dos ataques cibernéticos, as empresas não podem mais confiar em um único produto de segurança para protegê-las (MACHADO, 2014). Os profissionais de segurança precisam aplicar a defesa em profundidade a todos os ativos de TI, desde laptops de funcionários que precisam de proteção contra ataques intermediários, até a prevenção de sequestro de dados e informações (FREIRE, 2004).

Não existe uma única camada de segurança capaz de proteger contra todas as ameaças cibernéticas (LYRA, 2008). Os criminosos virtuais estão se tornando cada vez mais sofisticados em seus ataques, e as organizações precisam responder aprimorando suas defesas (PEIXOTO, 2006). Nesse contexto, as organizações precisam implementar várias camadas de segurança, cada uma com seu conjunto

específico de ferramentas de segurança para tratar vulnerabilidades e ameaças específicas àquela camada (LASTRE; ALBAGLI, 1999).

A estratégia de defesa em profundidade pode ser ilustrada pelo exemplo de um castelo medieval, no qual um invasor enfrenta diversos mecanismos de defesa distribuídos em camadas (STALLINGS, 2008). Cada camada de proteção é responsável por realizar uma proteção específica, dificultando e impedindo o acesso do invasor aos ativos protegidos no interior do castelo (FONTES, 2008). O aumento do nível de dificuldade em cada camada de proteção faz com que o invasor tenha uma maior dificuldade em superá-los ou mesmo desista de invadir o ambiente protegido (ABNT NBR ISO/IEC 27002:2013).

Estratégias de Defesa em Profundidade englobam três componentes principais:

Controles físicos: são medidas de segurança que previnem o acesso físico a sistemas de TI, incluindo guardas de segurança, cartões de acesso e portas trancadas.

Controles técnicos: são medidas de segurança que protegem a rede e outros recursos de TI através de hardware e software. Exemplos incluem sistemas de detecção de intrusões, firewalls, gerenciamento de configurações, proxies, scanners, gestão de identidades e acessos, antivírus, sistemas de prevenção de perda de dados, autenticação de dois fatores, biometria, gerenciadores de senhas, VPNs, criptografia de dados e sistemas de backup.

Controles administrativos: são medidas de segurança que abrangem políticas e procedimentos direcionados aos funcionários de uma organização, bem como fornecedores e parceiros comerciais. Incluem políticas de segurança da informação, gerenciamento de riscos, avaliações de segurança, treinamento e conscientização, e adoção de metodologias para promover a melhoria contínua.

Esses controles físicos, técnicos e administrativos compõem uma estratégia básica de defesa em profundidade. Além disso, muitos profissionais e equipes de segurança

utilizam ferramentas que monitoram continuamente a infraestrutura de TI quanto a possíveis falhas em suas defesas.

A defesa em profundidade é composta por camadas de proteção, e cada camada possui controles, mecanismos e ferramentas tecnológicas de segurança projetados para proteger os aspectos físicos, técnicos e administrativos de uma infraestrutura de TI.

Camada 1: Política, Procedimentos e Conscientização - implementa políticas e procedimentos que governam as práticas de segurança e conscientiza, treina e educa funcionários, fornecedores e parceiros comerciais.

Camada 2: Segurança Física - garante que as ameaças não tenham acesso físico aos ativos tangíveis, como servidores, desktops, dispositivos de rede, racks, painéis de controle elétricos e dispositivos de armazenamento.

Camada 3: Segurança de Perímetro - implementa proteção entre o mundo exterior e a infraestrutura interna de TI, fortalecendo as defesas ao longo da borda da rede.

Camada 4: Segurança da Rede Interna - gerencia a identidade e autenticação dos usuários, autorizando ou não o acesso aos recursos computacionais e de rede disponíveis na infraestrutura de TI.

Camada 5: Segurança de Hosts - foca na proteção dos hosts e seus sistemas operacionais, provendo mecanismos e ferramentas de proteção.

Camada 6: Segurança de Aplicação - mantém os aplicativos, sistemas de informação e outras aplicações seguras e protegidas contra diversas ameaças.

Camada 7: Segurança de Dados - protege os dados armazenados e em trânsito, concentrando-se na proteção dos dispositivos de armazenamento e na segurança dos dados enquanto estão sendo transmitidos.

Atividade Extra

Que tal aprendermos um pouco mais sobre a importância da segurança cibernética. Assistam a reportagem realizada pelo SBT Brasil, sobre os segredos cibernéticos.

- Segredos Cibernéticos - Parte 1

Conexão Repórter.

- Segredos Cibernéticos - Parte 2

Conexão Repórter.

Referência Bibliográfica

ABNT NBR ISO/IEC 27002:2013. **Tecnologia da informação – Técnicas de Segurança – Códigos de prática para controles de segurança da informação.** Disponível em: <<https://www.abntcatalogo.com.br/norma.aspx?Q=Q0I4Qy9ISjZqVnpBaEhIb2MzMHUzYmJ3N1h0cnBVTZLN1g5R2lXSVEbz0=>>>.

FONTES, E. **Praticando a segurança da informação.** Brasport, 2008.

FREIRE, Alexandre. **Sistemas de Firewall e Defesa de Perímetros.** Portal Módulo Security, 2004.

HARRIS, Shon. **CISSP All-in-one, 3. ed.:** Mc Graw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento.** Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, W. **Criptografia e Segurança de Redes. 4 ed.** São Paulo: Pearson, 2008.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas. 2.ed.** São Paulo; Elsevier, 2017.

PEIXOTO, M C P. **Engenharia Social e Segurança da Informação.** Brasport, 2006.